

Conceptos Clave para la Lectura

¿Qué es OWASP Top 10? Es el estándar global de concientización que representa el consenso de la industria sobre los 10 riesgos de seguridad más críticos en aplicaciones web. En este análisis utilizamos los criterios actualizados de validación.

¿Qué es RLS (Row Level Security)? Es una barrera de seguridad en la base de datos que garantiza que un usuario solo pueda leer o modificar su propia información, previniendo accesos no autorizados a datos de terceros.

Auditoría Estática: Esta revisión se enfocó en analizar la arquitectura y el código fuente en busca de debilidades, sin realizar ataques simulados (pentesting) contra la plataforma en vivo.

Resumen Ejecutivo

El presente documento certifica los resultados de la evaluación de seguridad realizada al código fuente de **CiberDojo** (repositorio shield-ecuador-app). La plataforma ha demostrado un alto nivel de madurez técnica, impulsado por un ciclo de auditoría previo en el cual se corrigieron vulnerabilidades de alto impacto (como XSS e inyecciones de dependencias).

Estado Actual de Seguridad

Se identificaron **0 vulnerabilidades Críticas y 0 Altas** en el código de producción. Existen actualmente 6 hallazgos menores (3 de severidad Media y 3 de severidad Baja). En su estado actual, la plataforma **no permite ejecución de código remoto ni fugas de credenciales**.

Cumplimiento OWASP

70% Cumplimiento Total

La plataforma satisface completamente 7 de las 10 categorías de riesgo, y cumple parcialmente las 3 restantes. Ninguna categoría fue ignorada.

Componentes Evaluados

App usuario (React/TS), Consola Admin, 68 migraciones de BDD (Supabase) y Funciones Edge. 100% de las tablas (52/52) protegidas con RLS.

Estado frente a OWASP Top 10 (2026)

El análisis contra las 10 categorías más críticas del Open Web Application Security Project demuestra un blindaje robusto en la gestión de accesos y protección de datos criptográficos.



Áreas de Cumplimiento Total (Selección)

Categoría OWASP	Evidencia de Protección en CiberDojo
A01: Control de Acceso Roto	Las 52 tablas de la base de datos cuentan con RLS activado. Un trigger (prevent_user_security_field_tampering) evita que un usuario eleve sus propios privilegios.
A02: Fallos Criptográficos	Gestión delegada a Supabase Auth. Prevención de ataques de temporización mediante crypto.timingSafeEqual. Claves de IA resguardadas en Supabase Vault.
A03: Inyección (SQL/XSS)	HTML generado de forma segura con esc(). Uso de PostgREST parametrizado para evitar inyecciones directas de SQL en las peticiones.
A10: SSRF	Módulo url-guard.ts prohíbe conexiones a IPs internas, obliga al uso de HTTPS y limita tamaños de respuesta para evitar falsificaciones.

Categorías con Cumplimiento Parcial

Las áreas **A04 (Diseño Inseguro)**, **A06 (Componentes Vulnerables)** y **A09 (Registro y Monitoreo)** se encuentran mitigadas en el producto final, pero carecen de documentación formal (falta un documento de modelado de amenazas), validación de alertas en vivo, o presentan librerías obsoletas exclusivas del entorno de desarrollo.

Análisis Detallado de Hallazgos

A pesar del robusto estado general, se registraron 6 hallazgos residuales. Estos elementos no representan riesgos de intrusión inminente, sino deuda técnica o brechas operativas en el ciclo de vida de desarrollo y monitoreo.

Severidad	Componente	Descripción del Hallazgo y Estado
Media	Frontend / Dependencias Dev	29 avisos en npm audit (14 altos) en el toolchain de construcción (react-scripts, webpack). <i>Estado: Pendiente.</i> No llegan al usuario final, pero exponen al entorno local de los desarrolladores.
Corregido	Consola Admin / Reportes	Limitación de 5.000 filas. Anteriormente, los totales se distorsionaban por el límite de descarga en altos volúmenes de tráfico. <i>Estado: Solucionado en este ciclo mediante conteo exacto de BDD.</i>
Corregido	Consola Admin / Gráfico 3D	Caída de tabla por error 3D. Si el navegador carecía de WebGL, echarts-gl bloqueaba todo el reporte. <i>Estado: Aislado exitosamente, la tabla de datos ahora persiste.</i>
Baja	Centro de Seguridad	Verificación operativa de Alertas. El código para webhooks y envío de correos es seguro (SSRF mitigado), pero no se ha validado su entrega real en producción. <i>Estado: Pendiente.</i>
Baja	Base de Datos / Roles	Modificación de roles sin documentar. Cambiar a admin vía SQL requiere set_config de service_role. Es la protección funcionando, pero confunde a nuevos DBAs. <i>Estado: Falta documentar.</i>
Baja	Diseño y Documentación	Ausencia de modelado de amenazas centralizado. Las lógicas y decisiones de seguridad están fragmentadas en comentarios de código y migraciones. <i>Estado: Pendiente.</i>

Impacto del Ciclo de Corrección

Es destacable que antes de la emisión de este reporte, se ejecutó un ciclo de corrección (evidenciado en DESIGN_REVIEW_CHECKLIST.md) que erradicó problemas graves como accesos anónimos a funciones de pago y exportación de CSVs vulnerables a inyección de fórmulas.

Plan de Acción Estratégico

Para alcanzar el 100% de cumplimiento operativo y documental, se recomienda al equipo técnico y de gobernanza ejecutar las siguientes acciones priorizadas. Ninguna de estas tareas bloquea la operatividad actual de CiberDojo.

1. Actualizar Cadena de Construcción

Prioridad Alta

Esfuerzo: Días.

Migrar el toolchain desactualizado (ej. react-scripts) a alternativas modernas como Vite. Esto purgará las vulnerabilidades locales que afectan los entornos de los desarrolladores.

2. Validar Centro de Seguridad

Prioridad Alta

Esfuerzo: Horas.

Realizar pruebas End-to-End (E2E) inyectando alertas simuladas en producción para corroborar que los Webhooks y correos electrónicos llegan al destinatario esperado.

3. Modelado de Amenazas

Prioridad Media

Esfuerzo: 1-2 Días.

Redactar un documento "One-Pager" que explique qué controles protegen qué activos. Esto democratiza el conocimiento de la arquitectura y acelera el *onboarding*.

4. Políticas de Retención de Logs

Prioridad Media

Esfuerzo: Horas.

Definir formalmente el periodo de almacenamiento de eventos críticos. Indispensable para futuras auditorías o investigaciones de incidentes (Categoría OWASP A09).

Conclusión del Auditor

CiberDojo ostenta una arquitectura sólida, haciendo honor a su lema "El Arte de Protegerte". Las vulnerabilidades tradicionales de la web (inyecciones, exposición de datos) están contenidas mediante el uso adecuado de RLS, frameworks modernos y validación rigurosa. El enfoque ahora debe desplazarse de la escritura de código seguro hacia la **Gobernanza**: documentar el diseño, asegurar la resiliencia de la infraestructura de monitoreo y mantener una rigurosa higiene en las herramientas de desarrollo.